

ПОЛИТИКА БЕЗОПАСНОСТИ

1. Общие положения и нормативная основа

Настоящая Политика конфиденциальности и безопасности персональных данных (далее – Политика) разработана во исполнение требований Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных» (далее – 152-ФЗ) и определяет правовой режим обработки, хранения и защиты персональных данных пользователей веб-приложения «ВАППИ» (далее – Оператор, Система). Действие Политики распространяется на все операции, совершаемые с персональными данными с использованием технических средств Системы, включая сбор, систематизацию, накопление, хранение, уточнение, извлечение, использование, передачу, обезличивание, блокирование, удаление и уничтожение. Целью Политики является обеспечение защиты прав и свобод субъекта персональных данных при обработке его данных, в том числе защита права на неприкосновенность частной жизни, личную и семейную тайну.

2. Перечень обрабатываемых персональных данных

В рамках функционирования веб-приложения «ВАППИ» Оператор осуществляет обработку следующих категорий персональных данных, предоставляемых субъектом добровольно и при наличии информированного согласия. Единственным идентифицируемым персональным данным является адрес электронной почты пользователя, выступающий в качестве уникального идентификатора учётной записи. В процессе аутентификации и обеспечения безопасности сеанса связи дополнительно обрабатываются следующие сведения: хэш пароля, сформированный с использованием криптографического алгоритма bcrypt; хэш refresh-токена; временные метки создания и обновления учётной записи; коды подтверждения действий (активации учётной записи, входа в систему, смены адреса электронной почты) со временем их генерации. Иные данные, генерируемые в процессе использования Системы (список избранного, история загрузок), не относятся к персональным данным в смысле 152-ФЗ, поскольку не позволяют идентифицировать субъекта вне контекста учётной записи.

3. Правовые основания обработки персональных данных

Обработка персональных данных осуществляется Оператором исключительно при наличии законных оснований, к которым в рамках настоящей Системы относятся: получение явного, информированного и добровольного согласия субъекта персональных данных на обработку его данных, оформленного в виде установки чекбокса при регистрации в форме электронного документа; исполнение договора, стороной которого либо выгодоприобретателем или поручителем по которому является субъект персональных данных (пользовательское соглашение); соблюдение обязанностей, возложенных на Оператора действующим законодательством Российской Федерации, в частности требований о хранении и защите персональных данных. Согласие на обработку персональных данных даётся субъектом на срок действия учётной записи и может быть отозвано путём направления письменного уведомления или через функционал удаления учётной записи, предусмотренный интерфейсом Системы.

4. Цели обработки персональных данных

Обработка персональных данных ограничивается достижением следующих строго определённых целей. Обеспечение идентификации и аутентификации пользователя при доступе к функциональным возможностям Системы, включая разграничение доступа на основе ролевой модели («Гость», «Пользователь», «Администратор»). Ведение личного кабинета пользователя, включая хранение истории загрузок медиа-контента и избранного, формирование отчётов о деятельности пользователя. Осуществление двухфакторной верификации при входе в Систему и при совершении критических операций (смена адреса

электронной почты) посредством отправки одноразовых кодов подтверждения на зарегистрированный адрес электронной почты. Информирование пользователя о плановых технических работах, изменениях в Политике и иных событиях, связанных с функционированием Системы. Исполнение требований законодательства, в том числе реализация права на забвение путём безвозвратного удаления персональных данных по требованию субъекта.

5. Принципы и условия обработки персональных данных

Обработка персональных данных строится на принципах законности, справедливости и прозрачности, соответствия целей обработки заранее определённым и заявленным целям, соответствия объёма и характера обрабатываемых данных заявленным целям обработки, недопустимости объединения баз данных, содержащих персональные данные, созданных для несовместимых целей, а также хранения данных в форме, позволяющей идентифицировать субъекта, не дольше, чем этого требуют цели обработки. Персональные данные не раскрываются третьим лицам без согласия субъекта, за исключением случаев, предусмотренных федеральным законом (в частности, по запросу уполномоченных государственных органов). Передача персональных данных операторам, осуществляющим обработку по поручению Оператора (аутсорсинг почтовых рассылок, хостинг), допускается только на основании договора, содержащего обязанность обеспечения конфиденциальности и безопасности обрабатываемых данных.

6. Организационные и технические меры защиты персональных данных

Оператором принят комплекс мер, направленных на предотвращение несанкционированного или случайного доступа к персональным данным, их уничтожения, изменения, блокирования, копирования, предоставления, распространения, а также иных неправомерных действий. К числу таких мер относятся: применение криптографического хэширования паролей и refresh-токенов с использованием алгоритма bcrypt (фактор стоимости 10), обеспечивающего необратимость преобразования и устойчивость к атакам перебора; шифрование данных, сохраняемых в клиентском сессионном хранилище (sessionStorage), с применением алгоритма AES-256 и динамически генерируемого ключа; использование протокола TLS для защиты передаваемых данных по сети, исключающего перехват JWT-токенов и учётных данных при атаках типа «человек посередине»; ограничение частоты запросов к эндпоинтам аутентификации (не более 20 запросов с одного IP-адреса в течение 5 секунд) посредством middleware express-rate-limit; настройка HTTP-заголовков безопасности с использованием библиотеки Helmet, включая политику безопасности контента, запрет на определение MIME-типов и защиту от кликджекинга; защита от загрязнения параметров HTTP-запроса (HTTP Parameter Pollution) с применением middleware hpp; санитизация и валидация всех входных данных на серверной стороне с использованием регулярных выражений по принципу «белых списков»; ведение детализированных журналов событий безопасности (логов) с фиксацией времени, типа операции, идентификатора субъекта и результата выполнения, доступ к которым ограничен лицами, ответственными за эксплуатацию Системы; размещение серверного оборудования и баз данных на территории Российской Федерации, что соответствует требованию о локализации хранения персональных данных российских граждан.

7. Реализация права на забвение и удаление персональных данных

Субъект персональных данных вправе требовать от Оператора безвозвратного удаления своих персональных данных в случаях, предусмотренных 152-ФЗ, в том числе при отзыве согласия на обработку, при достижении целей обработки либо при утрате необходимости в их достижении, а также при неправомерных действиях Оператора. В архитектуре Системы реализован механизм полного удаления учётной записи, доступный авторизованному пользователю через интерфейс личного кабинета. При выполнении данной операции

система инициирует процедуру удаления документа пользователя из базы данных «Енисей», включая все связанные с ним данные: избранный контент, историю загрузок, временные коды подтверждения, запросы на смену адреса электронной почты. Указанная операция является необратимой и не предусматривает восстановления данных. По истечении 24 часов с момента регистрации неактивированные учётные записи подлежат автоматическому удалению посредством TTL-индексирования, что исключает хранение персональных данных лиц, не завершивших процедуру верификации.

8. Сроки хранения персональных данных и порядок уничтожения

Персональные данные хранятся в форме, позволяющей идентифицировать субъекта, не дольше, чем этого требуют цели их обработки. Предельный срок хранения активной учётной записи не ограничен и определяется моментом отзыва согласия или удаления учётной записи пользователем. История загрузок медиа-контента хранится в течение трёх лет с момента последней активности, после чего подлежит автоматической очистке. Коды подтверждения (активации, входа, смены адреса электронной почты) хранятся не более пяти минут с момента генерации, что обусловлено требованием безопасности и защиты от атак повторного использования. Уничтожение персональных данных производится путём удаления соответствующего документа из базы данных «Енисей» с использованием HTTP-запроса DELETE, что исключает возможность восстановления данных средствами СУБД. В случае отсутствия технической возможности удаления (сбой базы данных) Оператор обязуется принять все доступные меры для блокирования доступа к персональным данным до момента их физического уничтожения.

9. Заключительные положения

Настоящая Политика является общедоступным документом, размещённым в постоянной электронной форме по адресу развёрнутого веб-приложения. Пользователь, проходящий процедуру регистрации, подтверждает, что ознакомлен с положениями Политики, понимает их содержание и даёт явное, информированное и добровольное согласие на обработку своих персональных данных в определённых Политикой целях и порядке. Оператор оставляет за собой право вносить изменения в Политику с обязательным уведомлением пользователей не менее чем за 10 календарных дней до вступления изменений в силу посредством электронной рассылки по зарегистрированным адресам. Все возникающие споры подлежат разрешению в соответствии с законодательством Российской Федерации по месту нахождения Оператора. Признание какого-либо положения Политики недействительным не влечёт за собой недействительности остальных положений.